

Política de Seguridad

Objetivos de seguridad

- Proteger confidencialidad, integridad y disponibilidad de datos y servicios.
- Reducir superficie de ataque mediante hardening de contenedores y aislamiento de red.
- Asegurar trazabilidad con logging centralizado y retención definida.
- Cumplir requisitos legales y contractuales aplicables.

Responsabilidades del equipo

- **Líder de seguridad:** define políticas, aprueba excepciones y coordina incidentes.
- **Dev/DevOps:** aplica hardening en código e infraestructura, mantiene dependencias y contenedores actualizados.
- **Ops/Soporte:** gestiona accesos operativos, monitoreo y backups.
- **Todos:** reportan hallazgos e incidentes de inmediato.

Política de contraseñas

- Longitud mínima 12 caracteres; mezclar mayúsculas, minúsculas, números y símbolos.
- Prohibido reutilizar credenciales y compartir contraseñas.
- Rotación semestral o tras incidentes; revocación inmediata al desuso.
- Almacenamiento seguro (secret manager o variables de entorno cifradas); nunca en repositorio.

Política de actualizaciones

- Aplicar parches críticos en ≤ 7 días, altos en ≤ 30 días.
- Usar imágenes base versionadas (no `:latest`) y actualizar dependencias con ciclo regular.
- Escanear imágenes/contenedores antes de promoción a ambientes superiores.

Gestión de accesos

- Principio de mínimo privilegio y separación de roles.
- Accesos a infra y datos solo vía cuentas nominativas; MFA donde sea posible.
- Revisiones periódicas de permisos y revocación al cese o cambio de rol.
- Acceso a base de datos a través de proxy y redes internas; no exponer puertos al host.

Retención de logs

- Centralizar logs en Loki (o equivalente) con etiquetado por servicio.
- Retención mínima 30 días en entorno de desarrollo; ajustar según cumplimiento en producción.
- Proteger integridad de logs (solo append, sin edición/borrado); acceso controlado.
- Registrar eventos de seguridad: autenticación, errores 401/403/429, cambios de configuración y accesos a datos sensibles.